
Headers HTTP e Autenticação

Metadados, tokens e JWT

O que são Headers

Metadados que acompanham toda requisição e resposta na web. Carregam informações extras sobre a comunicação entre o cliente e o servidor.

ANALOGIA: ENVIANDO UMA CARTA PELO CORREIO

Body

Conteúdo da carta

Método HTTP

O carteiro

Headers

O envelope: diz como interpretar a mensagem, não o conteúdo dela

Que tipo de informação vem neles?

Autenticação	Quem está fazendo a requisição?
Autorização	Esse usuário tem permissão?
Tipo de conteúdo	JSON, HTML, imagem, etc.
Compressão	Possui dados comprimidos?
Cache	Pode guardar dados em cache?
Segurança	Proteção contra ataques
Informação do cliente	Navegador, dispositivo, idioma, etc.

Visualizando Headers no Postman

POST http://localhost:3000/usuarios

Params Authorization Headers (9) Body Scripts Tests Settings

Toda requisição enviada pelo Postman já carrega headers. A aba **Headers** mostra a lista completa.

Capturando Headers no Node

```
const headers = req.headers;
```

Dentro do Controller, **req.headers** entrega todos os headers recebidos na requisição.

Headers de uma requisição

Key	Value
Cache-Control	no-cache
Postman-Token	<calculated when request is sent>
Content-Type	application/json
Content-Length	<calculated when request is sent>
Host	<calculated when request is sent>
User-Agent	PostmanRuntime/7.46.1
Accept	*/*
Accept-Encoding	gzip, deflate, br
Connection	keep-alive

Exemplo real de uso

Imagine que você precisa baixar um determinado arquivo *em partes*.

Motivo: conexão lenta, então precisamos baixar arquivos de tamanho menor.

COMO FAZER: USAR O HEADER RANGE

```
Range: bytes 0-9999
```

Nesse caso, nosso servidor vai receber isso e poder responder com apenas uma parte do recurso, conforme solicitado pelo cliente.

Autenticando usuários por token

HEADER

Authorization

Usado para dizer “Quem é você”, quando realiza uma requisição. Carrega informações como senha, token, chave, etc.

FORMATO

`<tipo> <chave>`

EXEMPLO

`Basic 123456abc`

SEGURANÇA

Por que preciso de tokens e autenticação?

Nem todo mundo pode acessar os dados.

Imagine se todo mundo pudesse acessar a API da XP Investimentos, por exemplo, e saber quanto dinheiro você tem investido lá, e pudesse manipular esse dinheiro.

AUTENTICAÇÃO

Tipos de token

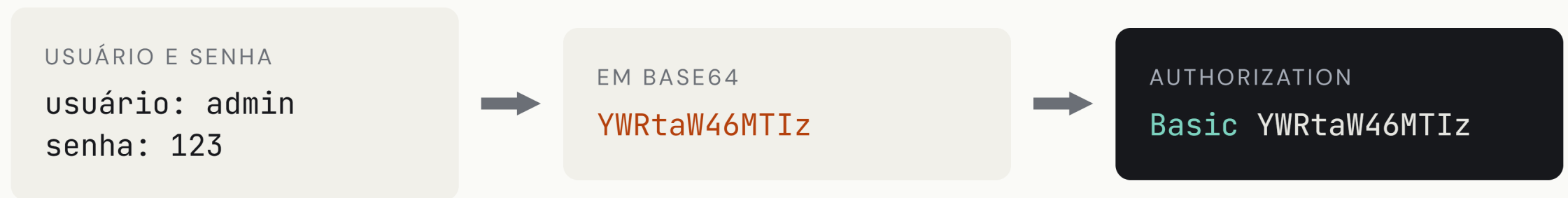
Basic

Bearer

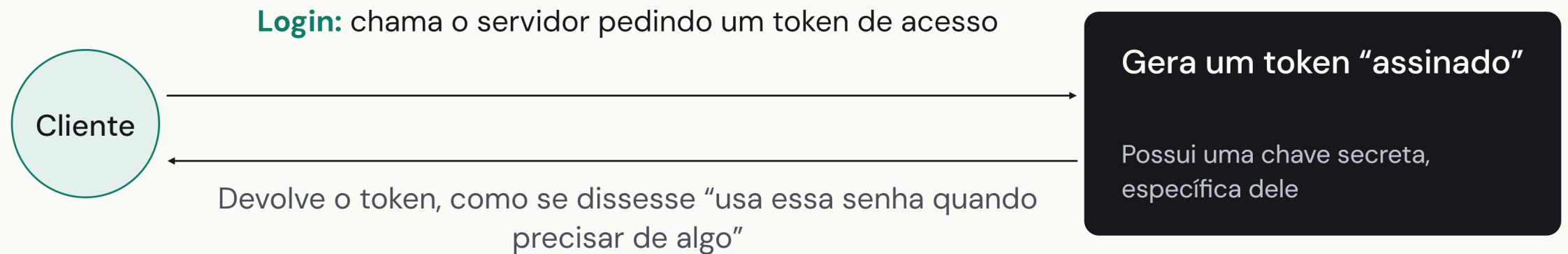
Basic

Funciona com **usuário e senha** codificados em Base64.

Base64 é um método de codificação que transforma dados em uma sequência de caracteres de texto ASCII.



Bearer



JWT: Json Web Token

Token assinado que **garante autenticidade**: se o conteúdo mudar, a assinatura não vai mais bater.

FORMAÇÃO DO JWT

header.**payload**.signature

Formação do JWT

Header

Diz qual algoritmo foi usado na assinatura

```
{  
  "alg": "HS256",  
  "typ": "JWT"  
}
```

Payload

Onde ficam os dados do usuário (email, nome, id, role, etc.)

```
{  
  "sub": "1234567890",  
  "name": "John Doe",  
  "admin": true,  
  "iat": 1516239022  
}
```

Signature

Garantia de que o token não foi adulterado

```
SECRET  
a-string-secret-  
at-least-256-  
bits-long
```

JWT.IO: vendo na prática

01 Gerar um token através do jsonwebtoken

02 Validar informações desse token no jwt.io

03 Gerar um token pelo jwt.io

04 Verificar os dados desse token via código

PRÁTICA

Vamos autenticar a nossa API com Basic Token

Authorization

Basic

Base64